

STEGASHIELD GATEWAY

Final Report and Viva Preparation Guide

Group 60 | SLIIT | Prepared 25 September 2026

Purpose: explain every expectation in the supplied final-report/final-viva slide and show how to address it using StegaShield. This is a preparation pack, not a declaration that the project is complete. No marking weights, interview responses, work hours or experimental results have been invented.

1. How to use this pack

Read Sections 2–8 to prepare the written report. Use Sections 9–12 to rehearse the viva and live demonstration. Complete the separate stakeholder and logbook templates using genuine records. Attach redacted evidence and rerun the final tests before submission.

The slide lists topics, not a full rubric. Confirm the required report format, page limit, citation style, presentation duration and individual assessment rules with the lecturer. This guide aligns with the supplied topics but cannot guarantee a grade.

The factual baseline is the original Group 60 proposal, the generated progress report, docs/assessment/readme.txt, and the current implementation documentation. The latest previously recorded checkpoint is 160 backend tests, 77 local database tests, 12 frontend tests, nine browser scenarios and a passing frontend build. These tests were reported during the 09 September profile-editing work; they were not rerun for this preparation pack. The older progress PDF contains earlier counts and must not be described as the final test record.

2. Final report: Background

What the assessor needs to understand

Explain the real problem, who experiences it, what existing controls do, and why your solution is worth investigating. Distinguish the problem from a list of technologies.

StegaShield-specific draft

Organisations can restrict access to sensitive documents, yet an authorised recipient may redistribute a legitimate downloaded copy through online channels. Access logs record interactions with the system but do not necessarily identify which issued copy corresponds to a recovered file. StegaShield investigates whether anonymous per-copy watermarking, combined with a protected server-side audit mapping, can support post-download attribution without embedding raw personal information in the document.

The solution complements access control and Data Loss Prevention; it is not a replacement for them. It does not automatically discover leaks on the internet. An authorised investigator must obtain and submit

a suspect file. Its contribution is an integrated, testable document-issuance and forensic workflow, not a proven claim that no previous watermarking or traitor-tracing system exists.

Include: problem scenario; intended organisation/users; comparison of access control, DLP, DRM and watermarking; bounded research gap; research question; objectives; and privacy considerations. Verify the proposal's bibliography before repeating academic citations. Avoid unsupported claims that every DLP product lacks attribution or that StegaShield is the world's first solution.

Evidence: proposal Sections 1–2, corrected literature table, a synthetic insider-sharing scenario, and an explanation of why a download event is more precise than a general account identifier.

3. Final report: Technology

Describe each technology's role, why it was chosen, its limitations and any replacement of the proposed stack. Do not list package names without explaining their contribution.

Layer/tool	Actual purpose	What to explain in the viva
React, TypeScript, Vite, Tailwind CSS	Browser member/admin portal and build workflow	Typed UI does not replace server authorisation
Python, FastAPI, Uvicorn	API validation, authentication dependencies and document processing	Why principal-derived identities are trusted instead of request-body IDs
Supabase Auth, PyJWT, JWKS	Login, token refresh, signed JWT verification	Signature, issuer, audience, expiry, algorithm allowlist and trusted app role
PostgreSQL/RLS, Supabase Storage	Permissions, audit mapping and private originals	Caller-scoped metadata versus narrowly scoped server operations
python-docx	DOCX structure and text carrier	Why zero-width symbols require underlying digital text
pypdf	Experimental static PDF carrier	Replaces proposed pikepdf; non-rendering marked-content points, not DOCX text runs
uuid, hmac, hashlib	Per-download UUID, HMAC-SHA256 tag and SHA-256 file hash	Randomness, authenticity and exact-file integrity are different properties
pypdfium2	Independent PDF renderer used in tests	Generated-fixture pixel equality is not universal compatibility proof
docx-preview and browser PDF viewer	Preview a recorded protected copy	No public original URL; DOCX frame isolation and rendering limitations
Pillow	Validate, resize and re-encode small profile photos; report figure generation	Not evidence that a DCT visual-watermark pipeline exists
pytest, pgTAP, Vitest, Playwright	Backend, database, frontend and browser checks	Local/mockend evidence differs from hosted end-to-end evidence
Supabase CLI, Docker, npm	Local database verification and frontend dependency/build tooling	Docker is not needed for normal use with hosted Supabase

The proposal already named React/Vite/Tailwind, Python/FastAPI and Supabase. TypeScript, concrete authentication/testing tools, DOCX preview and profile-image handling are implementation details/additions. OpenCV/DCT and Tesseract photo recovery are not implemented. The proposal

explicitly excludes photos/print but lists those tools elsewhere; document the inconsistency and obtain supervisor clarification rather than silently claiming completion.

Use requirements.txt and frontend/package-lock.json for the final dependency record. Do not call a declared version range an exact installed version. Never include actual .env values, service keys, passwords, session tokens or private production files in the report.

4. Final report: Methodology

Research approach

Use the proposal's design science approach: identify the post-download attribution problem; establish requirements and threats; design an artefact; build and integrate components; evaluate against explicit metrics; reflect on findings and limitations. Iterative development is the engineering process supporting that research, not a substitute for experiments.

Actual engineering sequence

The implementation established database/authentication boundaries, built and tested the protected DOCX download/forensic workflow, added the portal, validated the experimental PDF adapter, and introduced position access, previews, refresh persistence and profile editing. Present this as group implementation history supported by artefacts, not as invented personal dates or hours.

Explain the protected-download flow

1. Verify the access token and resolve the trusted application role.
2. Authorise the active document through an individual or job-position grant, or the existing admin privilege.
3. Retrieve the private original and verify its size/hash and absence of an existing mark.
4. Generate a fresh UUID and signed watermark; create the protected copy in memory.
5. Recheck relevant permissions/session state in the database recording transaction.
6. Return the file only after the download record is acknowledged.

The event proves issuance was recorded, not that the recipient finished reading the response. Opening Preview also issues a protected copy through this flow.

Explain the forensic flow

1. Require administrator access and append an attempt-started audit record.
2. Validate and parse the suspect document.
3. Recover a valid signed token without guessing between conflicting identities.
4. Look up its registered download record.
5. Compare the suspect SHA-256 with the stored protected-file hash.
6. Append the completed audit record before returning a matched/inconclusive result.

The HMAC authenticates the token, not every byte of the surrounding document. The exact-hash comparison prevents a transplanted valid token from causing a positive match for an unrelated file. Edited copies may therefore remain inconclusive even if extraction recovers the token.

Required experimental method

Complete the proposal's approximately 30–50-document corpus with supported DOCX and static PDF examples of varied sizes/layouts. Keep unsupported/encrypted/malformed inputs in a separate rejection set. Record format, application version, transformation, original/protected hash, expected token/event, measured latency and observed outcome. Use synthetic or permission-cleared files.

Metric	Measurement	Important distinction
Session uniqueness	Duplicate IDs / generated sessions	Measure per-download token uniqueness separately
Invisibility	Text/layout checks and render comparisons	State renderer, resolution, language and corpus scope
Extraction	Correct tokens / eligible marked files	Separate original issued copies and transformed copies
Robustness	Recovery after re-save/copy-paste/excerpt/conversion	Token survival is not positive attribution
Performance	Embed/extract/API latency and memory	Report hardware, repetitions, median/p95 and cold/warm conditions
Database security	Explicit negative authorisation cases	Passing selected cases does not prove exhaustive security
Attribution	Correct positive mappings / defined issued-file cases	Also report inconclusive cases
False attribution	Incorrect positive mappings / negative-control cases	Report the denominator even if zero observed

Do not graph invented success percentages. Planned charts are extraction by transformation, latency by document size and a matched/inconclusive/wrong-match matrix. Populate them only from saved results. Automated test counts are useful engineering evidence, not research accuracy rates.

5. Final report: Scope of solution

Capability	Current baseline	Limit / qualification
Authentication and app roles	Implemented	Current session_id claim is optional; local session rows are created during download rather than every login
Individual and position access	Implemented	Access is the union of grants; one position per member; prior copies cannot be recalled
DOCX watermarking	Implemented	Reformatting or sanitisation may strip markers
PDF watermarking	Opt-in experimental implementation	Static documents; non-rendering carrier; broader compatibility testing remains
Forensic exact-copy match	Implemented	Identifies issued copy/account, not proof of who leaked it

Session/IP in forensic result	Incomplete in documented implementation	Current result exposes event/user/document/time, not the full proposed evidence fields
Protected previews	Implemented	Preview is recorded issuance; screenshots/copied text are not attributable
Refresh-safe sessions	Implemented with sessionStorage	Tab-scoped, not permanent remember-me or HttpOnly cookies
Profile editing	Name and photo only	Email, user ID, role and position are not editable through this feature
Profile photos	Normalised JPEG stored privately under RLS	Small avatars, not document storage; no original uploaded image retained
Photo/print/screenshot tracing	Not supported	Excluded by main proposal scope; DCT/OCR table inconsistency needs clarification
Internet leak discovery	Not implemented	Investigator supplies recovered file
Public production deployment	Not certified/fully evidenced	Isolation, rate limits, recovery, retention and operational review remain

Explain additions as deliberate refinements: signed per-download tokens instead of reused login Session IDs; exact-hash attribution; dynamic position permissions; protected previews; profile editing; and concrete failure-handling/audit controls. Do not describe them as approved proposal amendments without an actual approval record.

6. Final report: Stakeholder feedback

No formal stakeholder interviews, questionnaire responses or sign-offs were supplied for this pack. Earlier statements that features worked are informal user feedback, not a substitute for a structured evaluation. Never invent participant quotes, percentages, satisfaction scores or meeting records.

Suggested participants: an intended document recipient, a document administrator/investigator, and the academic supervisor. Record role and consent without unnecessarily publishing their identity. Internal group testing should be labelled internal, not independent stakeholder validation.

Suggested session: explain the prototype and its limits; ask the participant to find/download a permitted document, inspect a preview, interpret a match versus inconclusive result, and, if an admin, grant/revoke member/position access. Observe errors, hesitation and misunderstandings. Ask whether the result makes clear that a matched account is not proof of a human perpetrator.

Use STAKEHOLDER_FEEDBACK_TEMPLATE.csv for raw observations. Summarise each finding as: observation -> impact -> decision -> implemented change or reason deferred -> retest outcome. Report how many people actually participated and how they were selected. Do not generalise a small convenience sample into organisational acceptance.

Example format only, NOT collected feedback: [Participant role] found [task/problem]; the team changed [specific control/text]; [retest date/evidence] showed [actual result]. Replace every bracket with a genuine record or omit the claim.

7. Final report: Documentation

Prepare a coherent final report rather than merely renaming the progress PDF. Include title/group details, abstract, contents, background, objectives, stack, design/methodology, implementation, scope, evaluation findings, stakeholder feedback, discussion/limitations, conclusion, verified references and appendices.

Document/evidence	Existing source or required action
Proposal comparison	docs/assessment/readme.txt and progress report; update with profile editing
System/API/data design	Backend routes, migrations and workflow guides
User manual	Sign-in, grants, downloads, previews, forensics, profile edit, errors and sign-out
Setup/admin guide	Root .env.example, dependency manifests, migration instructions and secret-handling rules
Test evidence	Fresh dated outputs; environment details; distinguish mocks/local DB from hosted tests
Research results	Corpus manifest, raw measurements, reproducible commands, analysed charts
Security documentation	Threat model, failure semantics, RLS boundaries, key/retention/deployment limits
Stakeholder evidence	Consent/role records, observed tasks, findings, changes and retests
Individual evidence	Logbook 2, genuine artefacts/commits, component explanation and integration work
Demonstration evidence	Redacted screenshots or recording using synthetic files/accounts

Existing figures can be reused from docs/assessment/figures with accurate captions. Review diagrams against the final code; do not treat old test-count figures as current. Avoid claiming OWASP/ISO certification or a completed penetration test. Cite official guidance as design guidance and verify academic bibliography entries independently.

8. Final report: Logbook 2

Logbook 2 should record each person's work since the previous assessed logbook period, using the lecturer's actual required dates. The supplied slide does not specify a minimum number of hours or entries. Do not copy dates/hours from another group's example, reconstruct personal labour from tool timestamps, or assign identical entries to everyone.

Each entry should contain actual date, objective, individual activity, decision/problem, artefact reference, actual hours, test/learning outcome, next action and review confirmation if required. Explain integration work as well as coding. Use LOGBOOK_2_TEMPLATE.csv; blank rows are intentional.

Member / proposal allocation	Useful evidence to select if personally contributed
Nethmika J.A.M. — IT23817258 / authentication gateway	JWT checks, session handling, permission boundaries, refresh/sign-out testing
K.K.R.L. Madhushani — IT23840546 / watermarking	Codec/adapters, HMAC, token conflicts, transformations, invisibility and performance experiments
L.P.M.S. Prasanna — IT23638136 / audit database	RLS/migrations, trusted recording, session/position tests, profile-photo privacy, recovery work

Liyanamana M. — IT24569072 / forensic portal	Matched/inconclusive UI, audited attempts, protected previews, profile UX, browser/accessibility testing
--	--

These are proposal responsibilities, not certified authorship. Members must describe their actual contributions and identify shared or AI-assisted work according to institutional policy.

9. Final viva: map each expectation to preparation

Slide expectation	What to demonstrate	Preparation task
Knowledge in domain	Explain insider risk, DLP/DRM, watermarking, authentication, authorisation, integrity and privacy	Give one example and one limitation of each relevant concept
Explanation of finding solution	Connect problem, alternatives, requirements and design tradeoffs	Explain why signed per-copy IDs and exact-file matching were selected
Core functionalities	Show allowed and denied workflows, not only successful screens	Rehearse the live demo in Section 11
Describing methodology	Connect design science, iterative implementation and actual experiments	Explain one test, its expected outcome and what it cannot prove
Communication skills	Give direct structured answers and acknowledge uncertainty	Use problem -> decision -> evidence -> limitation
Individual contribution	Demonstrate personally understood work and integration	Bring two genuine artefacts, a bug/decision and a verified logbook

Suggested opening statement

StegaShield is a browser-based gateway for investigating digitally shared copies of sensitive documents. Every authorised download receives an anonymous, signed per-download token, while identity mapping stays on the server. Administrators can examine a recovered file and identify an exact issued copy when both the signed token and stored file hash match. We implemented access control, private originals, DOCX and experimental PDF carriers, audited lookup and protected previews. Our main remaining research obligation is to quantify transformation robustness and performance; a match is not proof of which person leaked the file.

Use this as a model, not a memorised substitute for understanding. Update remaining-work statements when supported by real evidence.

10. Viva questions and model answers

Q1. What problem does the project solve?

It addresses the connection between a recovered digital document and an authorised download event. It complements preventive controls and provides controlled attribution evidence after a file has left the gateway.

Q2. How is this different from ordinary access logging?

An access log alone is not carried with the file. Our issued copy contains a token that can be resolved to an event, provided the file meets our signature and exact-hash checks.

Q3. Why not embed the user's name or email?

That would expose raw identity to anyone receiving the document. We embed an anonymous token and restrict the mapping. The token is still linkable within the trusted system; this is data minimisation, not absolute anonymity.

Q4. Why did you change the proposal's Session ID design?

A login session can contain several downloads. A fresh per-download UUID distinguishes issued copies and can reference the verified login session server-side. We disclose that refinement and must obtain any required academic approval.

Q5. What does HMAC add?

It detects changes or unauthorised fabrication of the encoded token frame using a server secret. It is symmetric message authentication, not encryption and not a public-key digital signature. Someone with the signing secret remains trusted.

Q6. Why compare SHA-256 if the token is signed?

The token signature does not bind all document bytes. A valid frame could be transplanted into another file. Comparing the entire suspect file to the recorded issued-file hash prevents that positive match under our current policy.

Q7. What happens if a genuine copy is re-saved?

The token may survive, but the file hash can change, so positive attribution becomes inconclusive. We must measure token survival separately from exact-copy attribution instead of presenting this as robust edited-file tracing.

Q8. Does a match prove who leaked the document?

No. It identifies an issued copy associated with an account/event. Credential theft, shared devices or another person obtaining the file remain possible. Interpretation needs additional investigative evidence.

Q9. Can you trace screenshots or printed copies?

No. Zero-width characters depend on digital structure and are not recoverable from rendered pixels. The proposal's main scope excludes these channels. DCT/OCR entries elsewhere are inconsistent with that scope and are not implemented capabilities.

Q10. How do DOCX and PDF carriers differ?

DOCX inserts zero-width frames into text structures. The experimental PDF adapter inserts a non-rendering marked-content point in page content. They share the signed-token codec, not identical embedding locations or transformation behaviour.

Q11. How is access enforced?

FastAPI authenticates the user and checks permissions, caller-scoped database queries apply RLS, and the trusted recording function rechecks relevant authorisation/session conditions before inserting the event. The frontend hiding a button is not the security boundary.

Q12. How do individual and job-position grants interact?

Either valid source grants access. Removing an individual grant does not cancel a position grant, and vice versa. A member has one current position, assigned by an admin. Changes affect future requests, not copies already issued.

Q13. Why record before returning the document?

Returning a marked copy without a durable mapping would break attribution. If recording fails or is not acknowledged, the API does not return protected-file bytes. A committed event followed by a network failure can still represent issuance rather than confirmed receipt.

Q14. What if forensic logging fails?

The API must not disclose a forensic result without the required audit operation. A start record is written before parsing; interruption may leave an unfinished attempt. That is an observable failure, not a fabricated successful investigation.

Q15. Where are the originals?

In a private Supabase Storage bucket with client access restricted. The API generates copies in memory and verifies original metadata. It does not publish original URLs or keep every generated protected copy as a stored file.

Q16. Are administrators completely unable to alter evidence?

Application/database protections restrict ordinary changes and make event rows append-only through supported roles. They do not make a database superuser or compromised server secret harmless, nor create external notarisation.

Q17. Why does refresh no longer sign the user out?

The browser now uses tab-scoped sessionStorage with Supabase session restoration/refresh. The application role is still server-verified. This is not permanent remember-me storage or an HttpOnly cookie architecture; same-origin XSS remains a concern.

Q18. Does preview bypass watermarking?

No. Preview requests a recorded protected copy through the download API. Saving from that preview saves the same copy. Browser rendering, screenshots and copied text do not preserve our exact-file guarantee.

Q19. What can users edit in their profile?

Only display name and profile picture. Unknown or privileged fields are rejected by the editing API. Pictures are decoded, bounded, resized and re-encoded as small JPEGs without source metadata, then stored in a private RLS table through a narrowly scoped trusted update.

Q20. How do you know it is secure?

We can demonstrate specified security properties through negative tests and explain the trust boundaries. We cannot claim universal security. Public processing isolation, rate limits, secret lifecycle, deployment checks and broader attack testing remain important.

Q21. What do your test totals prove?

They show the selected automated cases passed at a recorded checkpoint. They do not equal code coverage, research extraction accuracy, a production penetration test or hosted end-to-end verification. Final claims need fresh logs and experimental data.

Q22. What is your biggest remaining proposal gap?

The controlled evaluation is incomplete in the documented baseline. Mandatory session/login-audit semantics and the administrator-visible session/IP evidence fields also need resolution. These should be named directly rather than hidden behind cosmetic improvements.

Q23. What is your individual contribution?

Answer only with genuine work: I implemented/reviewed [component], made [decision] because [reason], tested it using [case], and integrated it with [other component]. Show [artefact]. Explain any shared/assisted work transparently.

Q24. What would you improve next?

Prioritise measured corpus evaluation and missing evidence semantics, then hard resource isolation, operational controls, administrative-change history, accessibility and pagination. Do not remove exact-hash checks simply to increase the number of apparent matches.

11. Live demo plan

The suggested 10-minute allocation below is a rehearsal plan, not an official time limit. Adapt it to the lecturer's instructions.

Approximate time	Action	Explain / verify
0:00–1:00	Introduce problem, scope and account roles	Digital file attribution, not screenshot tracing or proof of guilt
1:00–2:30	Admin uploads synthetic original; grants A but not B	Private original; trusted access boundary
2:30–4:00	A downloads twice; B is denied	Fresh token per copy; account identity from verified token

4:00–5:30	Admin investigates first unchanged download	Exact-copy match, restricted fields and audit event
5:30–6:30	Investigate original and modified copy	Inconclusive; no guessed user identity
6:30–7:30	Demonstrate position grant then revoke effective access	Union semantics and future-request enforcement
7:30–8:30	Preview, refresh, and edit display name/photo	Preview issues protected copy; privileged profile fields cannot change
8:30–10:00	Show test evidence, limitations and individual work	Distinguish automated fixtures, hosted proof and research results

Beforehand: confirm migrations on the intended project; start API/frontend; verify credentials and network; use separate browser contexts for admin/A/B; prepare original/unchanged/modified copies with known provenance; test PDF only if enabled; redact secrets. Include the avatar migration if demonstrating profile edits. Do not run unreviewed schema changes live in the viva.

Fallback: keep a labelled prerecorded demonstration and redacted screenshots/test outputs. If connectivity fails, state the limitation honestly and explain recorded evidence. Do not call mocked results a live hosted success.

12. Communication and individual rehearsal

Use a four-part answer: direct answer; mechanism; evidence; limitation. For example: "No, a signature alone does not prove the whole file is authentic. It signs the token, so we compare the issued-file hash too. The changed-file tests exercise this. Consequently re-saved copies can be inconclusive."

All four members should be able to explain the entire issuance/lookup flow, then go deeper into their own verified contribution. Each should prepare a two-minute component explanation, one design tradeoff, one bug and its test, one integration boundary and one limitation. Do not assign speaking credit based solely on the proposal table.

Rehearsal questions to ask one another: What if this check is removed? Who can call this function? What is trusted input? What happens if the database fails? What data leaves the server? Can a client alter this role? What does the test actually prove? Where is your personal evidence?

13. Final readiness checklist

Gate	Required evidence	Status to fill
Proposal reconciliation	Supervisor decision on session/token, PDF carrier and photo scope	[Pending actual confirmation]
Hosted functional validation	Real admin/member cases, grants, revocation, lookup and profile editing	[Record result/date]
Research evaluation	Actual corpus, measurements, transformation results and uncertainty	[Record result/date]
Missing evidence fields/session semantics	Implement/test or explicitly document approved limitation	[Record decision]
Stakeholder feedback	Real participants, observations, changes and retests	[Record evidence]

Documentation	Final report, user/admin guides, screenshots and verified references	[Review needed]
Logbook 2	Actual individual entries, hours and artefacts	[Each member completes]
Security/recovery	Deployment checks, secrets, resource limits and recovery evidence	[Record scope/limitations]
Viva rehearsal	Timed demo and individual technical explanation	[Record rehearsal]

Final recommendation: prioritise verifiable evidence and student understanding over additional visual polish. The project can be presented strongly without overstating robustness, novelty, production readiness or personal contribution.

Source notes

The supplied image IMG-20260924-WA0086.jpg supplies the seven final-report and six viva expectations. The original Group 60 proposal and previously prepared progress/change documents supply the project context. Implementation guides include DOCX_WORKFLOW.md, PDF_VALIDATION.md, WORKSPACE_UPGRADES.md and PROFILE_EDITING.md. This pack introduces no new research measurements and no fabricated stakeholder or logbook records.